

VirtuEx 시스템 감사 보고서 (17차)

VirtuEx System Audit Report (17th)

- 감사일: 2026-03-16
- 감사 범위: 인증/토큰 보안, API Gateway 라우팅, 비밀번호 정책, 입력 검증, CSP 설정, DB 스키마 무결성, CORS/내부 서비스, 알림 동기화
- 감사 방법: 전체 소스 코드 정적 분석 + API 흐름 추적 + 보안 취약점 패턴 매칭
- 심각도 기준: Critical(즉시 수정) / High(1주 내) / Medium(2주 내) / Low(개선 권장)
- 비고: 본 보고서는 발견 사항만 기록하며, 수정은 포함하지 않음

이전 감사 대비 수정 현황 (16차 → 17차)

이전 이슈	상태	비고
카피트레이딩 API 404 (경로 불일치)	수정됨	Gateway 컨트롤러 경로 api/portfolio/copy-trade → api/copy-trade 변경
채팅 초대 승인 사용자 미검색	수정됨	빈 쿼리 시에도 사용자 목록 로드, InviteModal 결과 표시 개선
언팔로우 확인 없이 즉시 실행	수정됨	커뮤니티/리더보드 양쪽에 언팔로우 확인 모달 추가
자기 자신 카피트레이딩 가능	수정됨	프론트엔드에서 자기 자신 카피트레이딩 버튼 비활성화
시스템관리자 전략 글쓰기 불가	수정됨	SYSTEM/ADMIN 역할에 전략 작성 자격 제한 면제 (프론트+백엔드)
감사보고서 UX개선 필터 미지원	수정됨	audit 페이지에 'ux' 타입 필터 추가
감사보고서 PDF 미생성 (15,16차/3,4차)	수정됨	누락 PDF 4건 생성 + manifest 경로 업데이트

요약 (Executive Summary)

카테고리	Critical	High	Medium	Low	합계
A. 인증/토큰 보안	1	0	1	0	2
B. API Gateway	0	0	2	2	4
C. 비밀번호/인증 정책	0	1	1	0	2
D. CSP/XSS 방어	0	0	1	0	1
E. DB 스키마/데이터 무결성	0	0	1	2	3
F. 알림/상태 동기화	0	0	0	1	1
G. 내부 서비스 통신	0	0	0	2	2

합계	1	1	6	7	15
----	---	---	---	---	----

A. 인증/토큰 보안 — 2건

[SEC-C-01] JWT 액세스 토큰 sessionStorage 저장 — XSS 취약점 (Critical)

현상: 코드 자체에 TODO 주석으로 "HttpOnly + Secure + SameSite 쿠키로 전환" 필요성이 명시되어 있음. JWT 액세스 토큰이 sessionStorage에 저장되어 페이지 내 실행되는 모든 JavaScript에서 접근 가능. 단일 XSS 취약점으로 모든 사용자 토큰 탈취 가능 **위치:** frontend/src/stores/auth.ts:37-38, 57-69 **권장:** 액세스 토큰을 HttpOnly 쿠키로 이전. 리프레시 토큰은 이미 쿠키 방식 — 동일 패턴 확장 **심각도:** Critical

[SEC-M-01] Pre-Hydration 스크립트 — DOM에 사용자 정보 노출 (Medium)

현상: 인라인 beforeInteractive 스크립트가 sessionStorage에서 읽어 HTML 요소에 data-authed, data-role, data-username 속성을 설정. 사용자 이름과 역할이 DOM에 노출되어 스크래핑 대상이 될 수 있음 **위치:** frontend/src/app/layout.tsx:49-70 **권장:** DOM 속성을 CSS용 최소 정보(data-authed="1")로 제한. 역할/사용자명은 노출 불필요 **심각도:** Medium

B. API Gateway — 4건

[GW-M-01] JwtStrategy — SERVICE_HOST 대신 localhost 하드코딩 (Medium)

현상: this.userAuthUrl = \ [http://localhost:\\${port}](http://localhost:${port}) \ 형태로 user-auth 서비스 URL을 생성. ProxyService는 SERVICE_HOST 환경변수를 사용하지만 JwtStrategy는 localhost 하드코딩. Docker/K8s 배포 시 통신 실패 **위치:** backend/services/api-gateway/src/auth/jwt.strategy.ts:32 **권장:** configService.getOrThrow<string>('SERVICE_HOST') 사용으로 ProxyService와 일관성 유지 **심각도:** Medium

[GW-M-02] 프록시 컨트롤러 — 입력 검증 없이 body 전달 (Medium)

현상: placeOrder(@Body() body: unknown, ...) 등에서 unknown 타입으로 body를 받아 하위 서비스에 그대로 전달. 명백히 잘못된 요청도 하위 서비스까지 도달하여 리소스 낭비 **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:48 **권장:** Gateway 레벨에 class-validator DTO 적용하여 조기 거부 **심각도:** Medium

[GW-L-01] 오더북 엔드포인트 — 인증 미적용 (Low)

현상: GET /api/orders/book/:symbol 만 @UseGuards(JwtAuthGuard) 없이 공개. 오더북 데이터는 일반적으로 공개이나 전체 보안 정책과 일관성 부족 **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:158-168 **권장:** 의도적 공개 엔드포인트로 문서화하거나, 인증 필요 시 가드 추가 **심각도:** Low

[GW-L-02] 거래 통계 엔드포인트 — x-user-id 헤더 누락 (Low)

현상: GET /api/orders/stats/trading 은 JwtAuthGuard를 사용하지만 하위 서비스에 x-user-id 헤더를 전달하지 않음. 사용자별 통계 필터링 시 실패 가능 **위치:** backend/services/api-gateway/src/proxy/order-proxy.controller.ts:138-154 **권장:** 다른 인증 엔드포인트와 동일하게 headers: { 'x-user-id': userId } 추가 **심각도:** Low

C. 비밀번호/인증 정책 — 2건

[PW-H-01] 비밀번호 초기화/로그인 엔드포인트 — 속도 제한 부족 (High)

현상: 주문 생성에는 `@Throttle({ default: { ttl: 60000, limit: 60 } })` 명시적 제한이 있으나, 비밀번호 초기화/SMS 인증/로그인 엔드포인트는 전역 스로틀(100req/분/IP)에만 의존. 공격자가 SMS 코드 브루트포스 또는 비밀번호 초기화 스팸 가능 **위치:** `backend/services/api-gateway/src/proxy/auth-proxy.controller.ts` **권장:** `/api/auth/forgot-password`, `/api/auth/verify-reset-sms`, `/api/auth/login` 에 5req/분 엔드포인트 별 제한 추가 **심각도:** High

[PW-M-01] 비밀번호 초기화 — 복잡성 검증 미흡 (Medium)

현상: `resetPassword()` 에서 `newPassword.length < 8` 만 검사. 회원가입 시 프론트엔드에서 소문자/숫자/특수문자 검증하지만, 비밀번호 초기화 백엔드에는 동일 규칙 미적용 **위치:** `backend/services/user-auth/src/application/services/auth.service.ts:672-674` **권장:** 회원가입과 동일한 비밀번호 복잡성 규칙(소문자, 숫자, 특수문자) 백엔드 검증 추가 **심각도:** Medium

D. CSP/XSS 방어 — 1건

[CSP-M-01] 프로덕션 CSP — `unsafe-inline` 허용 (Medium)

현상: 프로덕션 환경에서 CSP `script-src` 에 '`unsafe-inline`' 포함. 공격자가 주입한 인라인 스크립트가 실행 가능하여 XSS 방어력 약화 **위치:** `frontend/next.config.ts:9` **권장:** '`unsafe-inline`' 을 nonce 기반 또는 hash 기반 CSP로 대체. Next.js `generateNonces` 옵션 활용 **심각도:** Medium

E. DB 스키마/데이터 무결성 — 3건

[DB-M-01] `authorName` 비정규화 — 사용자명 변경 시 불일치 (Medium)

현상: `CommunityPost`, `CommunityComment`, `CommunityStrategy`, `CommunityStrategyComment` 모두 `authorName` 을 비정규화 필드로 저장. 사용자가 이름을 변경하면 기존 게시물/댓글의 이름이 갱신되지 않아 불일치 발생 **위치:** `backend/services/user-auth/prisma/schema.prisma:262, 295, 343, 379` **권장:** 이름 변경 시 캐스케이드 업데이트 메커니즘 추가, 또는 읽기 시 User 테이블 조인 **심각도:** Medium

[DB-L-01] `RefreshToken` — 만료 토큰 정리 미구현 (Low)

현상: `RefreshToken` 모델에 `expiresAt` 필드가 있으나, 만료된 토큰을 정기적으로 삭제하는 스케줄 작업 없음. 장기간 운영 시 테이블 비대 **위치:** `backend/services/user-auth/prisma/schema.prisma:70-81` **권장:** 만료 토큰 삭제 크론 잡 (`data-retention.service.ts`) 구현 **심각도:** Low

[DB-L-02] 프록시 컨트롤러 — `Record<string, any>` 타입 사용 (Low)

현상: `(req as Record<string, any>).user?.id` 로 사용자 정보를 추출하여 TypeScript 타입 검사를 우회. 인증 가드 실패 또는 user 객체 구조 변경 시 `undefined` 조용히 전파 **위치:** `backend/services/api-gateway/src/proxy/order-proxy.controller.ts:49, 185, 212, 256, 276` **권장:** 기존 `@CurrentUser()` 데코레이터 활용으로 타입 안전한 사용자 추출 **심각도:** Low

F. 알림/상태 동기화 — 1건

[NTF-L-01] 읽음 처리 후 미읽음 카운트 캐시 미갱신 (Low)

현상: `useMarkAsRead()` 뮤테이션이 `['notifications']` 캐시만 무효화하고 `['notifications', 'unread-count']` 캐시는 갱신하지 않음. 배지 카운트가 30초 풀링까지 잘못된 숫자 표시 **위치:**

frontend/src/hooks/useNotifications.ts:87-99 권장: onSuccess 콜백에
queryClient.invalidateQueries({ queryKey: ['notifications', 'unread-count'] }) 추가 심각
도: Low

G. 내부 서비스 통신 — 2건

[INT-L-01] 내부 마이크로서비스 — CORS 비활성화 (Low)

현상: 내부 서비스에 "Internal-only service -- CORS disabled" 주석이 있으나, 네트워크 레벨 격리 미적용. Docker 포트 매핑 실수 또는 방화벽 오설정 시 API Gateway 우회 직접 접근 가능 위치: backend/services/user-auth/src/main.ts:57-58 , backend/services/order-engine/src/main.ts:53-54 권장: 프로덕션에서 IP 화이트리스트 또는 내부 전용 네트워크 바인딩 적용 심각도: Low

[INT-L-02] dangerouslySetInnerHTML — img src 도메인 미제한 (Low)

현상: 커뮤니티 게시글에서 DOMPurify 정제 시 태그의 src 속성에 도메인 제한 없음. 외부 트래킹 픽셀 삽입 또는 SSRF 가능성 위치: frontend/src/app/(main)/community/[id]/page.tsx:379-382 권장: src 속성에 HTTPS 화이트리스트 도메인 검증 추가 또는 허용 태그에서 제외 심각도: Low

종합 의견

17차 감사에서는 총 15건의 이슈가 발견되었습니다. 16차 감사에서 발견된 카피트레이딩 API 404, 채팅 초대 검색, 언팔로우 확인, 자기 자신 카피 방지, 시스템관리자 전략 글쓰기, 감사보고서 필터/PDF 관련 7건의 이슈가 정상 수정된 것을 확인하였습니다.

Critical 1건(JWT 토큰 sessionStorage 저장)은 이전 감사에서도 지적된 장기 과제이며, XSS 취약점과 결합 시 전체 사용자 세션 탈취로 이어질 수 있어 우선 해결이 필요합니다. High 1건(비밀번호 초기화/로그인 속도 제한)은 브루트포스 공격 방어에 핵심적입니다.

API Gateway의 JwtStrategy localhost 하드코딩 이슈는 프로덕션 배포 환경에서 장애를 유발할 수 있으므로 조속한 수정을 권장합니다.

본 보고서는 자동 생성된 감사 결과이며, 수정 사항은 포함되지 않습니다.